

Ejercicio: Planta de Potabilización “AquaSur”

Fecha de Inicio: 20/09/2025

Fecha de entrega: 10/11/2025

Objetivo

Diseñar la arquitectura de redes OT/IT según Purdue, definiendo:

- **Celdas (zonas)** por proceso/función.
- **Conductos** (conexiones autorizadas entre zonas) y sus controles.
- **Topología de RD/VPN** para acceso remoto seguro (mantenimiento y operación).

Contexto (resumen operativo)

La planta toma agua cruda de río, la trata (coagulación, floculación, decantación, filtración, cloración) y la bombea a la ciudad. Hay un laboratorio de calidad y una sala de control local.

Inventario inicial (para partir)

- **Proceso:**
 - 6 PLCs: Toma/Bombeo (PLC-P1), Coagulación/Floculación (PLC-P2), Decantación (PLC-P3), Filtración (PLC-P4), Cloración (PLC-P5), Distribución (PLC-P6).
 - Instrumentación (sensores/actuadores) en cada etapa.
- **Control & Supervisión:**
 - 2 Estaciones HMI locales (Sala de Control).
 - 1 Servidor SCADA (on-prem).
 - 1 Historiador (on-prem).
- **Operaciones de sitio:**

- 1 Servidor de Reportes/ETL hacia DMZ.
- 1 Servidor de Ingeniería (programación PLC).
- **Perímetro/Interzona:**
 - 1 **DMZ Industrial** con: Relay de Historiador, Servidor de Archivos OT (parches/firmwares), Bastion/Jump-Server RDP.
 - 2 Firewalls: FW-OT (entre L3 y L3.5) y FW-Corp (entre L3.5 y L4).
- **Corporativo/Cloud:**
 - ERP (consumo de volúmenes producidos).
 - SIEM corporativo (recibe logs desde DMZ).
 - Nube para backup de reportes (opcional).
- **Acceso remoto:**
 - Contratista de mantenimiento PLC.
 - Equipo de operaciones 24x7 (guardia).
 - Dirección (solo reportes).

Red base sugerida (para que asignen)

- Superred: 10.10.0.0/16
- Requisito: asignar /24 por zona.
(Ej.: L2-Celdas 10.10.10.0/24, L2-Sala de Control 10.10.20.0/24, L3-Operaciones 10.10.30.0/24, L3.5-DMZ 10.10.40.0/24, L4-Corp 10.10.50.0/24)

Tareas para el alumno

1) Mapear celdas (zonas) por Purdue

- **Nivel 0/1:** Definir **celdas por etapa** (P1 a P6). Cada celda agrupa I/O + PLC asociado.
Entrega: lista de celdas con activos y subred asignada.
- **Nivel 2:** Sala de Control (HMI), red de programación (si la separan), servidores SCADA/Historiador (si los ubican aquí u otra zona L2.5).
- **Nivel 3:** Operaciones de sitio (servidor de reportes/ETL, server de ingeniería si no lo dejaron en L2).

- **Nivel 3.5 (DMZ):** Bastion RDP, Relay de Historiador, servidor de archivos/parches, Syslog/Forwarder.
- **Nivel 4/5:** Servicios corporativos, ERP, SIEM, nube (backups/reportes).

Requisito: Justificar **por qué** cada activo va en esa zona.

2) Definir conductos (conexiones permitidas)

Para cada par Zona A → Zona B:

- **Propósito** (ej.: SCADA ↔ PLCs tiempo real).
- **Dirección de flujo** (uni/bi-direccional).
- **Puertos/protocolos** (ej.: OPC-UA, Modbus/TCP, HTTPs, syslog).
- **Controles:** reglas de firewall, NAT, proxy/relay, inspección L7 si aplica, autenticación, listas de autorización por host.

Conductos mínimos a diseñar:

- L2 (SCADA/HMI) ↔ L1 (PLCs)
- L2/L3 (Historiador/ETL) ↔ L3.5 (Relay DMZ)
- L3.5 ↔ L4 (ERP/BI/SIEM)
- Mantenimiento: L4/L5 ↔ L3.5 (Bastion) ↔ L2 (solo vía RDP/SSH puente)

3) Diseñar acceso remoto RD/VPN

- **Modelo recomendado a evaluar:**
 - **VPN cliente-a-sitio** al **Concentrador VPN en DMZ** (L3.5).
 - Acceso **solo** a Bastion/Jump-Server (RDP/SSH) con MFA.
 - Del Bastion se salta a HMI/Servidor de Ingeniería según permisos (sin VPN directa a OT).
- **Alternativa:** VPN sitio-a-sitio (HQ ↔ Planta) para reportes/supervisión (no para programar PLC).
- **Definir:**
 - **Tipo de VPN** (IPsec/SSL), subredes permitidas, split-tunnel, cifrados mínimos.
 - **Flujo RD:** Origen remoto → VPN → Bastion (DMZ) → destino OT.
 - **Matriz de acceso** por rol (Contratista, Operador, Dirección).

4) Matriz de reglas de firewall (mínimo)

Completar una tabla por cada firewall (FW-OT y FW-Corp):

F W	De Zon a	A Zon a	Origen (IP/Subre d)	Desti no	Proto/PUer tos	Direc c.	Justificac ión	Control (MFA/Jump/Pro xy)
--------	----------------	---------------	---------------------------	-------------	-------------------	-------------	-------------------	---------------------------------

5) Plan de direccionamiento y nombres

- Subred por zona (/24).
- Reservas para servidores fijos (x.10-x.30), PLCs (x.100-x.150), HMI (x.200-x.220).
- Esquema de nombres (ej.: `PLC-P3.decant.ot.local`).

Entregables (para corregir)

1. **Diagrama Purdue** con zonas/celdas y conductos (incluye IPs y firewalls).
2. **Matriz de conductos** con protocolos/puertos y controles.
3. **Topología RD/VPN** (concentrador, bastion, MFA, saltos).
4. **Matriz de reglas FW** (resumida).
5. **Plan de direccionamiento** por zona y roles de acceso.
6. **Breve justificación** (1 página) de decisiones clave (riesgos mitigados + trade-offs).

Pistas/ayudas (pueden darlas luego de 15')

- Separar **HMI/SCADA** de **PLCs** (mínimo FW entre L2↔L1).
- Todo acceso remoto **pasa por DMZ** (bastion con MFA, sin RDP directo a OT).
- **Historiador**: escribir en OT, **publicar** a DMZ (pull desde L4).
- **Contratistas**: ventana horaria + grabación de sesión en bastion.

Criterios de evaluación

- **Zonificación (celdas)** clara y consistente con procesos (25%).
- **Conductos** mínimos y justificados, con puertos/protocolos y sentido (25%).
- **RD/VPN** seguro (bastion, MFA, separación roles, sin túneles planos a OT) (25%).
- **Reglas FW + direccionamiento** coherentes y principio de mínimo privilegio (15%).
- **Claridad del diagrama/entregables** (10%).